

1. Scenario: Risk Identification

Your organization is adopting the NIST RMF and you've been tasked to conduct a risk assessment. You identify that one of your third-party vendors has weak security controls. What should you do next according to NIST RMF?

- A. Accept the risk
- B. Mitigate the risk
- C. Communicate the risk to senior leadership
- D. Terminate the contract

Answer: C

Explanation: In the NIST RMF, risks identified through assessments should be communicated to senior leadership so that they can make an informed risk-based decision on mitigation, acceptance, or avoidance. Risk mitigation or contract termination may be options but require executive decision-making.

2. Scenario: Framework Implementation

Your company is implementing NIST CSF and needs to prioritize security activities. What step of the NIST CSF should you focus on to align your priorities with business objectives?

- A. Identify
- B. Detect
- C. Respond
- D. Recover

Answer: A

Explanation: The "Identify" function in NIST CSF helps an organization understand its business context, assets, and risks, and aligns security activities with business objectives, making it the foundational step for prioritizing security efforts.

3. Scenario: System Categorization

Your organization must implement the NIST RMF for a new information system. What is the first step you should take according to the RMF?

- A. Monitor security controls
- B. Authorize the system
- C. Categorize the information system
- D. Select security controls

Answer: C

Explanation: The first step in the NIST RMF is to categorize the information system based on its impact levels, which determines the security controls needed. This aligns with the FIPS 199/200 standards.

4. Scenario: Supply Chain Risk

While adopting the NIST CSF, you realize that the cybersecurity risks posed by your supply chain are not well understood. What should your organization do?

- A. Ignore supply chain risks as it falls outside your direct control
- B. Include supply chain risk management in your “Identify” function
- C. Focus only on internal risks
- D. Wait until an incident occurs to assess supply chain risks

Answer: B

Explanation: The “Identify” function of the NIST CSF includes understanding and managing risks related to the supply chain, ensuring that external vendors and partners are part of the risk management strategy.

5. Scenario: Incident Response

Your organization’s security incident response plan is being built as part of the NIST CSF. Which function of the CSF focuses on incident response?

- A. Detect
- B. Protect
- C. Respond
- D. Identify

Answer: C

Explanation: The “Respond” function in the NIST CSF addresses the response to detected cybersecurity incidents and includes activities like planning, communications, analysis, and mitigation.

6. Scenario: Control Selection

You are tasked with selecting security controls for a high-impact system as per NIST RMF. Which NIST Special Publication provides guidance for selecting the appropriate controls?

- A. SP 800-39
- B. SP 800-53
- C. SP 800-171
- D. SP 800-30

Answer: B

Explanation: NIST SP 800-53 provides a catalog of security and privacy controls to be used

for selecting appropriate controls based on the system's impact level (low, moderate, or high).

7. Scenario: Framework Adaptation

Your organization is a small business looking to adopt NIST CSF but is concerned about the resources required. How can the CSF be adapted?

- **A.** It must be implemented in full, regardless of size
- **B.** It cannot be adapted; use an alternative framework
- **C.** Use a risk-based approach to prioritize CSF functions relevant to the organization
- **D.** Implement the CSF as written but gradually over time

Answer: C

Explanation: NIST CSF is flexible and scalable. Small businesses can prioritize functions based on their specific risks and business needs, focusing resources on critical areas first.

8. Scenario: Continuous Monitoring

Under the NIST RMF, your team has implemented security controls. What's the next step in the RMF lifecycle?

- **A.** Categorize the system
- **B.** Monitor the controls continuously
- **C.** Implement more controls
- **D.** Decommission the system

Answer: B

Explanation: After implementing security controls, continuous monitoring is essential in the NIST RMF to ensure the controls remain effective in the evolving threat landscape.

9. Scenario: Framework Core

Which part of the NIST CSF helps an organization create a customized risk management profile?

- **A.** Tiers
- **B.** Implementation Tiers
- **C.** Framework Core
- **D.** Profiles

Answer: D

Explanation: NIST CSF Profiles are used to customize the framework to meet the specific needs of an organization, balancing risk tolerance and business needs.

10. Scenario: Risk Mitigation

Your organization identified multiple risks during the NIST RMF risk assessment process. What is the appropriate step for managing these risks?

- **A.** Implement all controls from NIST SP 800-53
- **B.** Prioritize and implement cost-effective controls
- **C.** Ignore low-level risks and focus on high-level risks
- **D.** Wait until an attack occurs to address them

Answer: B

Explanation: NIST RMF encourages risk-based decision-making, meaning controls should be selected and implemented based on cost-effectiveness and alignment with risk tolerance.

11. Scenario: Integration with Other Frameworks

You're tasked with integrating the NIST CSF into your existing ISO 27001 Information Security Management System. How do you approach this?

- **A.** Abandon ISO 27001 and use NIST CSF exclusively
- **B.** Implement both frameworks side by side with no overlap
- **C.** Map NIST CSF functions to relevant ISO 27001 controls
- **D.** Use NIST CSF only for regulatory reporting

Answer: C

Explanation: NIST CSF can be mapped to ISO 27001 controls to create an integrated security program, ensuring the organization benefits from both frameworks.

12. Scenario: External Audits

During an external audit, the auditor requests evidence of compliance with the "Respond" function of NIST CSF. What documentation should you provide?

- **A.** Business continuity plans
- **B.** Risk assessment reports
- **C.** Incident response plans and response activities
- **D.** Vulnerability management scans

Answer: C

Explanation: The “Respond” function focuses on an organization’s ability to manage incidents, so incident response plans and documentation of response activities are relevant evidence.

13. Scenario: Risk Communication

Your organization has finished its risk assessment under the NIST RMF. Who is the primary audience for communicating these risks?

- **A.** Only IT teams
- **B.** Business stakeholders and senior leadership
- **C.** External vendors
- **D.** All employees

Answer: B

Explanation: The NIST RMF requires communicating risks to business stakeholders and senior leadership for informed decision-making regarding risk acceptance, mitigation, or avoidance.

14. Scenario: Baseline Security Controls

How do you determine which baseline security controls are necessary for a system under NIST RMF?

- **A.** Use the same controls for all systems
- **B.** Select controls based on the system’s impact categorization
- **C.** Randomly select controls from NIST SP 800-53
- **D.** Only use controls that are low-cost

Answer: B

Explanation: Baseline security controls are selected based on the system’s categorization (low, moderate, high) to ensure the controls are proportional to the system's potential impact.

15. Scenario: Recovery Planning

Which NIST CSF function is most concerned with developing and executing recovery strategies?

- **A.** Protect
- **B.** Detect
- **C.** Respond
- **D.** Recover

Answer: D

Explanation: The “Recover” function in NIST CSF focuses on resilience, including recovery planning and activities to restore capabilities and services that may be impaired during a cybersecurity incident.

1. Scenario: Risk Acceptance

Your organization has identified a risk with a low probability but high impact. After conducting a risk assessment, senior management decides not to take any action to mitigate it. What risk management strategy is being applied?

- A. Risk Mitigation
- B. Risk Avoidance
- C. Risk Acceptance
- D. Risk Transfer

Answer: C

Explanation: Risk acceptance occurs when an organization decides to acknowledge the risk and not implement any controls to mitigate it, usually due to cost-benefit analysis or strategic considerations.

2. Scenario: Inadequate Control

During a risk assessment, you find that an important security control is only partially effective. What is the most appropriate course of action?

- A. Accept the risk
- B. Ignore the control
- C. Recommend control enhancement
- D. Implement a new control

Answer: C

Explanation: If a control is found to be partially effective, enhancing the control is a practical step to improve its effectiveness rather than replacing it or ignoring it.

3. Scenario: Identifying Threats

While conducting a risk assessment, you are tasked with identifying threats to the organization’s information assets. Which of the following is NOT a valid threat category?

- A. Natural disasters
- B. System vulnerabilities
- C. Insider threats

- **D. External attackers**

Answer: B

Explanation: System vulnerabilities are weaknesses that could be exploited by a threat but are not threats themselves. Threats are external or internal agents that could exploit vulnerabilities, such as disasters, attackers, or insiders.

4. Scenario: Risk Response Strategy

Your company has a business-critical system that is vulnerable to a specific cyber threat. You have recommended transferring the risk. What is the most likely action to take?

- **A. Outsource the function to a third-party provider**
- **B. Accept the risk without action**
- **C. Implement additional security controls**
- **D. Stop using the system**

Answer: A

Explanation: Risk transfer involves shifting the risk to a third party, such as through outsourcing, insurance, or contracts. This does not eliminate the risk but transfers the financial or operational impact.

5. Scenario: Control Effectiveness

You are evaluating the effectiveness of current security controls in your organization. What is the best approach to determine whether these controls are mitigating the intended risks?

- **A. Review security control documentation**
- **B. Conduct a vulnerability scan**
- **C. Perform a control effectiveness assessment**
- **D. Rely on user feedback**

Answer: C

Explanation: A control effectiveness assessment determines whether controls are functioning as intended and effectively mitigating the identified risks.

6. Scenario: Selecting Controls

During a risk assessment, a medium-level risk has been identified. You are tasked with selecting an appropriate control to mitigate the risk. What factor is MOST important in choosing the control?

- **A. Cost of the control**

- **B.** Potential impact on business operations
- **C.** Ease of implementation
- **D.** Complexity of the control

Answer: B

Explanation: While cost and complexity are important, the impact on business operations is critical. Controls should not disrupt essential processes or reduce productivity without compensating benefits.

7. Scenario: Risk Assessment Approach

You are leading a risk assessment and need to determine which approach to use. What is the key difference between a quantitative and a qualitative risk assessment?

- **A.** Quantitative uses subjective assessments, while qualitative is based on hard data
- **B.** Quantitative assigns numerical values to risks, while qualitative uses descriptive terms
- **C.** Qualitative provides more accurate results than quantitative
- **D.** Quantitative only applies to financial risks

Answer: B

Explanation: A quantitative risk assessment assigns numerical values to risk factors (e.g., probability, impact), while a qualitative approach uses descriptive terms like “high” or “low.”

8. Scenario: Residual Risk

Your organization has applied several controls to mitigate a risk, but some level of risk still remains. What is the term for the risk that persists after controls are applied?

- **A.** Inherent risk
- **B.** Residual risk
- **C.** Accepted risk
- **D.** Mitigated risk

Answer: B

Explanation: Residual risk is the risk that remains after controls have been implemented. It reflects the amount of risk an organization has chosen to accept.

9. Scenario: Control Categorization

A critical system requires controls to protect against unauthorized access. Which type of control would be most effective at preventing unauthorized access?

- A. Detective control
- B. Corrective control
- C. Preventive control
- D. Recovery control

Answer: C

Explanation: Preventive controls are designed to stop unauthorized actions before they occur. Examples include access control mechanisms and authentication methods.

10. Scenario: Risk Appetite

The organization's risk assessment identified some high-impact, low-probability risks. How should the organization decide whether to mitigate these risks or accept them?

- A. Conduct a cost-benefit analysis
- B. Mitigate all high-impact risks regardless of cost
- C. Accept all low-probability risks
- D. Rely on historical data to make a decision

Answer: A

Explanation: A cost-benefit analysis helps determine whether the cost of mitigating a risk is justified by the potential reduction in impact, considering the organization's risk appetite.

11. Scenario: Control Monitoring

Your organization has implemented several controls to mitigate identified risks. What ongoing activity is necessary to ensure that the controls remain effective over time?

- A. Control elimination
- B. Continuous control monitoring
- C. Conducting an annual audit
- D. Periodic risk reassessment

Answer: B

Explanation: Continuous monitoring of controls ensures they remain effective and relevant as the threat landscape and business environment change.

12. Scenario: Control Gaps

A recent audit revealed a significant gap in your organization's security controls. What should be your immediate next step?

- A. Escalate the issue to senior management

- **B.** Begin a risk assessment to determine the potential impact
- **C.** Implement a temporary control
- **D.** Investigate how the gap occurred

Answer: B

Explanation: Before taking other actions, it's important to conduct a risk assessment to determine the potential impact of the control gap and prioritize the response.

13. Scenario: Third-Party Risk

Your company is assessing the risks associated with a third-party vendor's access to your systems. What type of control can help reduce the risk of unauthorized access by this vendor?

- **A.** Technical control
- **B.** Administrative control
- **C.** Physical control
- **D.** Transfer control

Answer: A

Explanation: Technical controls, such as encryption, firewalls, and access control mechanisms, can help prevent unauthorized access by third-party vendors.

14. Scenario: Risk Avoidance

During a risk assessment, your team identifies a risk that could cause major disruption to business operations. The cost to mitigate the risk is high, but the potential impact is deemed unacceptable. What risk response strategy is most appropriate?

- **A.** Risk Acceptance
- **B.** Risk Transfer
- **C.** Risk Avoidance
- **D.** Risk Mitigation

Answer: C

Explanation: Risk avoidance involves taking actions to eliminate the risk entirely, such as changing business processes or stopping the use of a risky service or technology.

15. Scenario: Risk Management Framework

Your organization has adopted a formal risk management framework. What is the main benefit of using such a framework?

- **A.** It allows for continuous control updates

- **B.** It provides a systematic approach to identifying, assessing, and mitigating risks
- **C.** It ensures that all risks are eliminated
- **D.** It mandates a one-time risk assessment

Answer: B

Explanation: A risk management framework provides a structured approach for identifying, assessing, and managing risks, ensuring consistency and thoroughness across the organization.